

WILMS

Women's Interest-Free Loan Management System

Security & Compliance Book — v1.7.3

WILMS Security & Compliance Book

Version: 1.7.3 Classification: Confidential

1. Security overview

WILMS implements defence-in-depth across authentication, authorization, transport, data, and audit layers. This book documents controls as deployed through v1.7.2.

2. Authentication controls

| Control | Implementation |

|-----|-----|

| Session mechanism | HMAC-signed cookies (wilms_session) |

| Password storage | bcrypt hashing |

| Login rate limiting | IP and account level |

| OTP challenge | Optional second factor on login |

| Password reset | Time-limited single-use tokens |

| Session invalidation | Force-logout capability |

| Demo account guard | Production environment blocks demo logins |

WILMS does not use Auth.js, OAuth, or JWT bearer tokens for browser sessions.

3. Authorization controls

| Control | Implementation |

|-----|-----|

| RBAC | Five roles via @wilms/shared-rbac |

| Permission middleware | Domain requirePermission + frontend middleware |

| Permission overrides | Admin-granted, audited |

| Route protection | Role-scoped route prefixes |

| Maker-checker | Expense submit " approve; loan approval separation |

4. Transport security

| Control | Implementation |

|-----|-----|

| HTTPS | Vercel enforced |

| HSTS | Production enabled (1 year, includeSubDomains) |

| Helmet headers | CSP, referrer policy, hidePoweredBy |

| CORS | Restricted to configured origin |

| CSRF | Mutating BFF path protection |

5. Data protection

| Control | Implementation |

|-----|-----|

| Money integrity | Integer pesewas, no float |

| Payment immutability | Day-end lock on collections |

| Pool hard-stop | Cannot over-disburse |

| Upload allowlist | Restricted file types |

| Audit log | Append-only, no deletion |

| Export confidentiality | Footer on all generated exports |

6. Rate limiting and abuse prevention

- Global API: 300 req/min
- Login-specific limiters
- Redis-backed when REDIS_URL configured
- Request ID on all requests for traceability

7. Audit and compliance

Audit log

Every privileged action recorded: actor, action, target, timestamp, reason. Immutable. Queryable by auditors.

Compliance artefacts

- Compliance pack export from executive intelligence
- Branded PDF exports with confidentiality notice
- Role-scoped report access

Data retention

Audit log retained indefinitely. No automated purge. Partner data processing agreements govern PII handling.

8. Residual risks

Risk	Severity	Mitigation status
Adjustment self-approve	Medium	Documented; manual policy
Expense self-post APPROVED edge case	Medium	Maker-checker enforced in UI
Large-history report aggregations	Low	422 fail-closed on oversized
No statutory GL	N/A by design	Deferred v2.0

9. Compliance frameworks alignment

Framework	Alignment
SOC 2 Type II	Partial — controls documented; formal audit not performed
ISO 27001	Partial — security practices align; not certified
GDPR	Partner DPA required; no automated data subject portal
Ghana DPA	Programme-level compliance via partner agreements

10. Incident response

See Operations Manual for P1–P4 severity procedures. Security incidents require ops incident creation and programme director notification.

CONFIDENTIAL — For authorized WILMS personnel, executive review, procurement, and official record keeping only.